

Response to Reviewers

Previous submission: Computer Networks, COMNET-D-25-04940R2

Deferred Asynchronous Post-Quantum Signature Verification for Low-Latency TLS 1.3 Handshakes

We thank Reviewers #4 and #5 for their careful reading. Their comments led to a substantial rewrite. The main changes are:

1. The contribution is repositioned as a client-side, implementation-level scheduling strategy with specified local state semantics, not a protocol mechanism (R5.1).
2. The motivation now separates confidentiality (HN DL, addressed by hybrid key exchange) from authentication (PKI migration lead time, Mosca’s inequality), and explains what DAPV does and does not address (R4 detailed 1).
3. New Background (PQ schemes, hybrid constructions, TLS 1.3 authentication modes) and a broadened Related Work section with 15 new references (R4.1, R4.2, R4 detailed 2).
4. New analysis showing that the measured latency gain is two orders of magnitude larger than the cost of PQ arithmetic, with the consequences stated plainly; new discussion of threads versus SIMD (R4.1, R4.4, R4.6).
5. The latency model is corrected: extra round trips arise from the TCP initial congestion window, not from exceeding the MTU; our own data show $\delta k = 0$ for the single-certificate configuration.
6. The exponential risk model (old Eq. 6, old Fig. 11) and the mixed- baseline efficiency metric (old Eq. 7, old Table 3) are removed; the leakage bound now includes the congestion-window limit (R5.3, R5.4).
7. All interpolated and extrapolated values are removed; only measured values are reported (R5.8). Six figures and three tables were removed or merged, and each result now opens with its takeaway (R5.6, R5.7).
8. A Threats-to-Validity section discusses co-location, loopback emulation, chain length and timer resolution (R4.4, R4.5).

[AUTHOR INPUT: Items marked “pending” below need new experiments or information from the authors. Update this letter once they are done.]

Reviewer #4

Comment. *W1. Writing style: introduction and background/related work are too short; decisions such as using threads rather than instruction-level parallelism (AVX2/AVX-512) are not justified.*

Response. The Introduction has been rewritten and extended (Sections 1.1–1.5), and the former one-page “Background and Related Work” is now two sections (Sections 2 and 3). The threads-versus-SIMD question is answered in the new Section 4.6: the two are complementary. SIMD shortens one verification and is already used (liboqs AVX2 code); deferral moves the remaining time off the critical path. We also acknowledge explicitly that for one AVX2 ML-DSA-44 verification (≈ 0.1 ms) deferral can save at most that amount, and identify the cases where synchronous PQ work is large enough to matter: multi-certificate chains, multi-algorithm credentials, SLH-DSA and devices without vector units. Independent verifications in these cases can be parallelised across cores, which SIMD cannot do.

Changes. Sections 1, 2, 3 and 4.7.

Comment. *W2. The literature review is too narrow.*

Response. Section 3 now covers PQ-TLS measurement studies, size-reduction work (KEMTLS and its variants, intermediate-certificate suppression, mixed certificate chains), hybrid-signature theory and

IETF composite signatures, asynchronous cryptographic offload in TLS (QTLS/OpenSSL async), TLS False Start and 0-RTT as precedents for accepting a bounded weaker guarantee, and formal analyses of deferred authentication. Table 5 positions DAPV relative to these by the cost addressed and approach. In revising the bibliography we also found and corrected two entries that did not match the cited works (the former Cremers2016 and Cheval2022).

Changes. Section 3, Table 9, bibliography.

Comment. *W3. The implementation was not made available.*

Response. The code, load generator, scripts and raw data are released at **[AUTHOR INPUT: URL and DOI]**. Section 5.1 now describes the implementation in detail: which function was modified, how the job is created, how the result reaches the connection, and which parts of the design (bounded pool, ticket handling, API) are implemented in the prototype.

Changes. Sections 5.1 and 5.2. **[AUTHOR INPUT: pending: release]**

Comment. *W4. Methodology: client and server on the same machine compete for CPU; number of repetitions not justified and too few; why multithread if PQC verification is fast; how many certificates are used; throughput with one host is hard to trust.*

Response. We agree with each point and have addressed them as follows. (i) *Co-location*: the throughput metric is renamed “completed-handshake rate” and explicitly described as a property of the combined client–server system. We explain that since DAPV only changes the client, part of the gain may come from reduced client-side CPU contention, which would not occur with separate hosts (Section 6.3). **[AUTHOR INPUT: pending: re-run with separate hosts or disjoint pinned cores and report server-only throughput.]** (ii) *Repetitions*: Section 5.6 now justifies 30 runs: with standard deviations below 4% of the mean, the 95% CI half-width is about 1.5% of the mean, an order of magnitude below the reported differences. We also acknowledge that Δt is much more dispersed and that 30 runs are insufficient for tail percentiles. **[AUTHOR INPUT: pending: state the number of handshakes per run; increase the Δt sample to ≥ 1000 handshakes.]** (iii) *Why threads*: see W1 and the new Section 6.2, which shows that the measured saving is not explained by the cost of verification. (iv) *Certificates*: Section 2.3 states the chain used **[AUTHOR INPUT: number of certificates]**. Section 4.7 computes the server flight size and shows that it remains below the initial congestion window, consistent with the equal slopes observed. Threats to validity (Section 6.7) explains that 2–3-certificate chains would increase both the size cost and the amount of PQ work that can be deferred. **[AUTHOR INPUT: pending: measurements with a 2- or 3-certificate chain.]**

Comment. *W5. netem may not trigger real TCP behaviour, local traffic bypasses the NIC queue, a single certificate does not trigger TCP mechanisms, and it is unclear whether PQC key exchange is used.*

Response. We agree. The Threats-to-Validity section now states that on the loopback interface (64 KB MTU, segmentation offload) segment counts and congestion-window behaviour differ from those on a real path, and that we therefore make no claim about MTU-induced segmentation. We also corrected the model (Eq. 1): an extra round trip occurs when the server flight exceeds the initial congestion window, not merely the MTU. The key exchange is stated in Section 5.4: **[AUTHOR INPUT: group]**. It is identical across all configurations, so differences are due to authentication alone. **[AUTHOR INPUT: pending: repeat hybrid configurations with X25519MLKEM768 and over a real interface or veth pair between namespaces/hosts.]**

Comment. *W6. Marginal contribution; consider hybrids with more than two algorithms, which could use multiple verification threads.*

Response. We have narrowed and sharpened the claims instead of overstating them. The contribution is now framed as (1) provisional-state semantics, including ticket, resumption and alert handling that were not specified before; (2) a prototype; (3) a measurement and decomposition that shows where the gain actually comes from; and (4) a risk characterisation. The reviewer’s multi-algorithm suggestion is adopted in the design: Algorithm 1 generalises to submitting each PQ component as an independent job, and Section 4.6 identifies this, together with multi-certificate chains, as the setting where thread-level deferral is most useful. **[AUTHOR INPUT: pending: if possible, add a three-algorithm experiment (e.g., P-256 + ML-DSA-44 + SLH-DSA or FN-DSA).]**

Comment. *D1. The motivation is HNDL, which concerns confidentiality, while the proposal concerns authentication; PKI migration is not mentioned; the hybrid-for-interoperability claim is inaccurate; why hybrid, why concatenation, what alternatives; fragmentation is motivated but not addressed.*

Response. All accepted. Section 1.1 separates HNDL (confidentiality, countered by hybrid key exchange) from the authentication threat (active impersonation once a CRQC exists) and explains why authentication must nevertheless migrate now: PKI lead times and Mosca’s inequality. Section 1.2 corrects the statement about interoperability: hybrid authentication is a hedge against breaks of the young PQ schemes, not an interoperability mechanism; a composite certificate is not verifiable by clients that do not support it. Section 2.2 describes the four hybrid constructions (composite/concatenation, nested extensions, parallel chains, mixed chains), their trade-offs, and which of them DAPV applies to. The abstract and introduction now state that DAPV addresses only the computational component of the cost and not size or fragmentation.

Changes. Abstract, Sections 1.1, 1.2, 2.2.

Comment. *D2. Background does not explain PQC, available algorithms, how to choose, what hybrids are, or how TLS authentication works (not only certificates; 0-RTT, PSK; Certificate message also carries signatures).*

Response. New Section 2.1 describes ML-DSA, FN-DSA and SLH-DSA, the assumptions behind them and the selection trade-offs, with a size table (Table 1). Section 2.3 describes the three TLS 1.3 authentication modes (certificate-based, PSK/resumption with 0-RTT, post-handshake), notes that chain validation also requires signature verifications in the `Certificate` message, and explains how DAPV interacts with each mode. A new rule (Section 4.3) prevents a provisional session’s tickets from being used for resumption or 0-RTT before promotion. **[AUTHOR INPUT: Section 2.3: state whether the prototype defers the PQ components of chain signatures or only of CertificateVerify.]**

Comment. *D3. Section 3 needs more discussion; some messages of Fig. 1 are not explained; design goals.*

Response. Fig. 1 has been redrawn and now shows all TLS 1.3 messages; every numbered step is explained in Section 4.2. Design goals and non-goals are listed in Section 4.1.

Comment. *D4. The key-exchange algorithm is not stated; ML-KEM adds bytes and computation.*

Response. Stated in Section 5.4 **[AUTHOR INPUT: group]**. Table 1 gives the X25519MLKEM768 share sizes (1216/1120 bytes; the reviewer’s figure of 800 bytes corresponds to the ML-KEM-512 public key). **[AUTHOR INPUT: pending if re-measured with X25519MLKEM768.]**

Comment. *D5. Algorithm 1 dispatches the PQC verification after verifying ECDSA. Why not dispatch first to run in parallel? Algorithms are not explained.*

Response. Explained in Section 4.5 (“Dispatch order”): dispatching only after σ_E verifies prevents an attacker without a valid classical signature from consuming workers, and the classical verification takes only tens of microseconds, so the difference in Δt is negligible. Implementations may dispatch first and cancel on failure. All three algorithms are now explained in the text, and the functions they use are defined.

Comment. *Minor: “carries” should be “carry”.*

Response. The sentence has been rewritten.

Reviewer #5

Comment. *1. Is DAPV a protocol-level contribution or an implementation-level scheduling optimisation?*

Response. It is implementation-level; we agree with the reviewer. DAPV changes no message and needs no server support. All “protocol-level” claims have been removed; the Introduction (Section 1.4) states the positioning explicitly, and the standardisation discussion (Section 8) now says that no TLS extension is required, only implementation guidance on the provisional semantics.

Comment. *2. What happens in the transition from provisional to fully_authenticated? Is there re-keying?*

Response. No. Section 4.3 (“Promotion does not re-key”) explains that the transition is a local state change, why re-keying is unnecessary (the keys depend only on the key-exchange secret and the transcript), and what this means for data sent during Δt in both the success and failure cases.

Comment. *3. Justify Equation (6): where does β come from, and what event does $R(\Delta t, B)$ represent?*

Response. On re-examination we could not justify β empirically, and the exponential form did not correspond to a well-defined event. We have removed Eq. (6) and its figure. Exposure is now characterised only by the deterministic bound of Eq. (3), which we have strengthened to include the TCP congestion-window limit.

Comment. *4. Justify Equation (7), which mixes baselines.*

Response. We agree the mixed baselines were not meaningful. The metric and its table have been removed; the results report latency and rate changes directly against consistent baselines (Section 6.6).

Comment. *5. Justify the 8 KB cap.*

Response. It is a heuristic default, not an empirical result. Section 7.2 (“Choice of D_{policy} ”) explains that the correct value depends on what data the application will reveal to a classical-only authenticated peer, and gives the reasoning behind 8 KB as a default.

Comment. *6. Clarify the purpose of Tables 2 and 4.*

Response. Old Table 2 (Δt decomposition, now Table 2) supports the takeaway that Δt is dominated by scheduling, not cryptography; this is now stated at the start of Section 6.5. Old Table 4 has been removed because most of its entries were interpolated or extrapolated (see comment 8).

Comment. 7. *Improve the presentation of the evaluation.*

Response. Removed: old Fig. 3 (duplicated Fig. 2), Fig. 6 (duplicated Figs. 4 and 5), Fig. 7 (CPU, now in Table 3), Fig. 8 (duplicated Table 2), Fig. 10 (replaced by Table 1 with correct sizes), Fig. 11 (risk model), old Table 3 (efficiency) and Table 4 (interpolated). Each subsection of Section 6 now begins with a one-sentence takeaway.

Comment. 8. *Why were interpolation and extrapolation used?*

Response. They should not have been. All interpolated and extrapolated values have been removed and only measured values are reported. **[AUTHOR INPUT: Explain whether latency at 20/50/100 ms was actually measured (now Fig. 3, which shows points there). If measured, say so; if not, remove those points.]**

Comment. 9. *Was the $\Delta t < 1$ ms thread-pool result implemented or projected?*

Response. It was a projection. The revised text says so explicitly, removes it from the abstract and conclusions, and labels the corresponding column of Table 4 as hypothetical. **[AUTHOR INPUT: pending: if a bounded pool is implemented and measured, report it.]**

Comment. 10. *VerifyPQC() is not defined; unresolved references in Section 5.7.*

Response. VerifyPQC and VerifyECDSA are defined in Section 4.5, including the message they verify. The unresolved references (to an undefined equation label and figure label) have been fixed; the revised manuscript compiles without undefined references.

We thank both reviewers again.